1.4 Network Security

OCR GCSE Computer Science (J277) — Paper 1

Network security protects computer systems, networks, and data from unauthorised access, damage, and theft. A comprehensive security strategy combines multiple layers of protection — no single measure is sufficient on its own. Understanding both the threats and their countermeasures is essential.

1.4.1 Forms of Attack

Attacks can be broadly categorised into **social engineering** (exploiting human psychology) and **technical attacks** (exploiting software/hardware vulnerabilities). Many attacks combine both.

Malware

> **Malware** (malicious software) is any software intentionally designed to cause damage, steal data, or gain unauthorised access. It is installed without the user's informed consent, typically via email attachments, infected downloads, compromised websites, or infected USB drives.

Type	How It Works	Key Characteristic
Virus	Attaches itself to a legitimate file or program. When the infected file is opened/executed, the virus activates and can copy itself to other files.	Requires **user action** to spread (e.g., opening an infected file). Cannot spread on its own.
Worm	Self-replicating malware that spreads across networks **without any user**	Spreads **automatically** across networks. Can consume bandwidth and system resources even without a payload.

© RAG Learning · Not for redistribution

	action. Exploits vulnerabilities in operating systems or network services.	
Trojan	Disguised as legitimate, useful software (a game, utility, or update). Once installed, it performs hidden malicious actions in the background.	**Does not self-replicate** — relies on tricking users into installing it. Named after the Trojan Horse from Greek mythology.
Spyware	Secretly monitors user activity: keystrokes (keylogger), browsing history, screenshots, webcam, microphone. Sends collected data to the attacker.	Designed to be **invisible** to the user. Can capture passwords, credit card numbers, and private communications.
Ransomware	Encrypts the victim's files with a strong encryption key, then displays a ransom demand (typically in cryptocurrency) for the decryption key.	Files are **irrecoverable without the key** (or a backup). Paying the ransom does not guarantee decryption. Prevention and backups are the only reliable defences.
Adware	Displays unwanted advertisements, pop-ups, and redirects browser to advertising sites. May track browsing habits for targeted advertising.	More annoying than destructive, but can slow systems and sometimes bundle more dangerous malware.

Impact of malware: Corrupt or delete files; steal personal data (passwords, banking details, identity information); give the attacker remote control of the system; encrypt files for ransom; slow down the system; use the computer as part of a **botnet** (network of compromised computers controlled remotely for DDoS attacks or spam); damage hardware (in rare cases, e.g., Stuxnet targeting industrial control systems).

Phishing

> **Phishing** is a social engineering attack where fraudulent emails, texts (smishing), phone calls (vishing), or fake websites **impersonate legitimate organisations** to trick users into revealing sensitive information. It exploits **human trust** rather than technical vulnerabilities.

How phishing works:

1. The attacker creates a convincing fake email or website that closely mimics a trusted organisation (bank, HMRC, Amazon, a social media platform).
2. The message creates **urgency** ("Your account will be suspended!", "Unusual activity detected!") or **opportunity** ("You've won a prize!") to pressure quick action.
3. A link directs the victim to a fake website that looks identical to the real one.
4. The victim enters their credentials, credit card details, or personal information, which are captured by the attacker.
5. The attacker uses the stolen information for identity theft, financial fraud, or account takeover.

Spear phishing is a targeted variant that uses personal details (from social media, data breaches, or company websites) to craft highly personalised, convincing messages aimed at specific individuals. Much harder to detect because the message appears to come from someone the victim knows.

How to spot phishing: Generic greetings ("Dear Customer"); urgency/threats; spelling and grammar errors; mismatched URLs (hover over links before clicking); requests for sensitive information; unexpected attachments; sender email address that does not match the claimed organisation.

Brute-Force Attack

> A **brute-force attack** uses automated software to **systematically try every possible password combination** until the correct one is found. Given enough time and computing power, any password can theoretically be cracked — the question is whether it takes seconds or centuries.

Variations of brute-force attacks:

- **Pure brute force** — tries every possible combination of characters. Effective against short passwords but impractical for long ones.
- **Dictionary attack** — tries common words, phrases, and known passwords from leaked databases. Much faster than pure brute force because most people choose predictable passwords.
- **Credential stuffing** — uses username/password pairs leaked from other data breaches, testing them against different services. Works because many people reuse passwords across sites.

© RAG Learning · Not for redistribution

```
Password strength comparison:
  4-digit PIN:         10,000 combinations        → cracked in seconds
  6-char lowercase:    308 million combinations    → cracked in minutes
  8-char mixed case:   218 billion combinations    → cracked in hours
  12-char mixed+symbols: 475 trillion combinations → cracked in years
  16-char mixed+symbols: practically unbreakable by brute force

Key insight: each additional character MULTIPLIES the number of
combinations. A 16-character password is not twice as strong as
8 characters — it is billions of times stronger.
```

Denial of Service (DoS / DDoS)

> A **Denial of Service (DoS)** attack floods a server with so many fake requests that it cannot respond to genuine users, effectively taking the service offline. A **Distributed DoS (DDoS)** attack uses a **botnet** — thousands or millions of compromised computers — to generate the flood from many sources simultaneously, making it much harder to block.

How a DDoS attack works:

1. The attacker infects thousands of computers with malware, creating a **botnet** (the owners of these computers usually do not know they are compromised).
2. The attacker sends a command to all botnet machines simultaneously.
3. Every botnet machine sends floods of requests to the target server.
4. The target server is overwhelmed — it cannot distinguish fake requests from legitimate ones.
5. Genuine users receive timeout errors or extremely slow responses. The service is effectively offline.

Impact: Financial losses (e-commerce sites losing sales); reputational damage; disruption to critical services; used for extortion, competitive sabotage, or as a distraction while another attack occurs simultaneously.

Why DDoS is hard to stop: The attack comes from thousands of different IP addresses (each a real compromised computer), so you cannot simply block one source. The traffic looks similar to legitimate requests, making filtering difficult.

Data Interception (Man-in-the-Middle)

> In a **man-in-the-middle (MITM) attack**, an attacker secretly **intercepts data travelling between two parties** on a network. The attacker can read, modify, or inject data without either party knowing. Both sides believe they are communicating directly with each other.

Common scenarios:

- **Unsecured public Wi-Fi** — an attacker on the same open Wi-Fi network (coffee shop, airport) can intercept unencrypted traffic between your device and the router.
- **ARP spoofing** — the attacker tricks devices on a LAN into sending traffic through their machine by poisoning the ARP table (associating their MAC address with the router's IP).
- **Fake Wi-Fi hotspot** — the attacker sets up a rogue access point with a legitimate-sounding name (e.g., "Airport_Free_WiFi"). Users connect, and all their traffic flows through the attacker's device.

Prevention: Use HTTPS (encrypted); use a VPN on public Wi-Fi; verify SSL certificates; avoid entering sensitive data on unsecured networks.

SQL Injection

> **SQL injection** is an attack where malicious SQL code is entered into a web form input field (e.g., login form, search box). If the web application does not properly **sanitise** (validate and escape) user input, the malicious SQL is executed directly by the database server, potentially giving the attacker full access to the database.

How SQL injection works — step by step:

```
-- The web application has a login form. When the user submits their
-- username and password, the application constructs an SQL query:

SELECT * FROM Users WHERE username='[input]' AND password='[input]';

-- Normal login: user enters username "admin" and password "pa55word"
SELECT * FROM Users WHERE username='admin' AND password='pa55word';
-- This returns the admin row only if the password matches. Correct behaviour.
```

```
-- SQL INJECTION: attacker enters password: ' OR '1'='1
SELECT * FROM Users WHERE username='admin' AND password='' OR '1'='1';

-- Breaking this down:
--   password=''         → this is false (empty string is wrong password)
--   OR '1'='1'          → this is ALWAYS TRUE
--   False OR True       → the WHERE clause evaluates to TRUE
-- Result: the attacker is logged in as admin WITHOUT knowing the password!

-- Even worse: attacker enters:  '; DROP TABLE Users; --
SELECT * FROM Users WHERE username='admin' AND password=''; DROP TABLE Users; --';
-- This DELETES the entire Users table from the database!
-- The -- is a comment that ignores everything after it.
```

Prevention — parameterised queries (prepared statements):

```
-- VULNERABLE code (string concatenation — NEVER do this):
query = "SELECT * FROM Users WHERE username='" + username + "'"

-- SAFE code (parameterised query — ALWAYS do this):
query = "SELECT * FROM Users WHERE username=? AND password=?"
-- The ? placeholders ensure user input is ALWAYS treated as DATA,
-- never as executable SQL code. Even if the user enters SQL syntax,
-- it is treated as a literal string, not as part of the query.

# Python example using parameterised query:
cursor.execute("SELECT * FROM Users WHERE username=? AND password=?",
               (username, password))
```

Exam Tip: For each threat, the exam expects you to explain **HOW it works** (the mechanism) AND its **purpose/impact** (what the attacker gains) — these are separate marks. For SQL injection specifically, be able to give a concrete example of the malicious input (e.g., `' OR '1'='1`) and explain how parameterised queries prevent it by treating input as data rather than executable code. A common mistake is confusing social engineering attacks (phishing — exploits humans) with technical attacks (SQL injection — exploits software).

1.4.2 Prevention Methods

Effective security uses **defence in depth** — multiple overlapping layers of protection so that if one layer fails, others still provide security. No single measure is sufficient alone.

Prevention	What It Protects Against	How It Works
Penetration testing	All vulnerabilities (finds them before attackers do)	Authorised **ethical hackers** (also called white-hat hackers), with written permission, attempt to break into systems using the same techniques as malicious hackers. They systematically probe for vulnerabilities in networks, applications, and configurations. Findings are documented in a detailed report with recommendations for fixing each weakness. Should be conducted regularly (at least annually and after major system changes). The key distinction from malicious hacking is **authorisation** — penetration testers have written permission.
Anti-malware software	Malware infections (viruses, worms, trojans, ransomware, spyware)	Uses two main detection methods: **Signature detection** — compares files against a database of known malware patterns (signatures). Effective against known threats but cannot detect brand-new (zero-day) malware. **Heuristic/behavioural analysis** — monitors program behaviour for suspicious patterns (e.g., a program trying to modify system files, encrypt many files rapidly, or send data to unknown servers). Can detect unknown malware but may produce false positives. **Must be kept updated** — hundreds of thousands of new malware variants are created daily. Provides real-time protection (scanning files as they are opened/downloaded) and scheduled full-system scans.
Firewall	Unauthorised network connections and intrusions	Monitors all incoming and outgoing network traffic and **allows or blocks** connections based on predefined security rules. Rules filter by IP address, port number, protocol, and direction. Can be **hardware** (standalone device at the network boundary, protecting all devices behind it) or

© RAG Learning · Not for redistribution

		software (running on individual computers, protecting just that machine). A firewall does NOT scan file contents for malware — that is the anti-malware's job. Think of a firewall as a security guard at the door checking ID, while anti-malware is like a detective searching for hidden weapons inside.
User access levels	Damage from compromised accounts; insider threats; accidental damage	The **principle of least privilege**: each user is given the minimum access rights needed to do their job and no more. An office worker does not need administrator access to the server. If their account is compromised, damage is limited to what that account can access. Common levels: **Administrator** (full control), **Standard user** (run programs, access own files), **Guest** (very limited, read-only). This limits the "blast radius" of any security incident.
Strong passwords	Brute-force attacks, dictionary attacks, guessing	Passwords should be: **Long** (12+ characters — length matters most); **Complex** (mix of uppercase, lowercase, digits, symbols); **Unique** (different for every account — a breach at one site should not compromise all accounts); **Not predictable** (no names, birthdays, dictionary words, or common patterns like "Password1!"). Use a **password manager** to generate and store unique passwords. Enforce password policies: minimum length, complexity requirements, account lockout after failed attempts.
Encryption	Data interception and theft (both in transit and at rest)	Converts readable **plaintext** into unreadable **ciphertext** using a cryptographic algorithm and a key. Only someone with the correct decryption key can convert it back to plaintext. Protects data **in transit** (HTTPS/TLS encrypts web traffic; VPNs encrypt all network traffic) and **at rest** (full-disk encryption like BitLocker; encrypted databases). Even if data is intercepted or stolen, it is useless without the decryption key. The strength of encryption depends on the key length — modern AES-256 encryption is considered unbreakable with current technology.

© RAG Learning · Not for redistribution

Physical security	Unauthorised physical access to hardware	Locked server rooms with key card/PIN access; CCTV surveillance; biometric locks (fingerprint, retina scan); cable locks for laptops; visitor sign-in logs and escorts; security guards; locked cabinets for backup media. Physical security is often overlooked but critical — if an attacker can physically access a server, they can bypass almost all software security measures (e.g., by removing the hard drive, booting from a USB drive, or installing a hardware keylogger).
Two-factor authentication (2FA)	Account compromise even when password is stolen	Requires **two different categories** of evidence to log in: (1) Something you **know** (password or PIN), (2) Something you **have** (phone for SMS code, authenticator app, security key), or (3) Something you **are** (fingerprint, face recognition, retina scan). Even if an attacker steals the password, they cannot log in without the second factor. Authenticator apps (e.g., Google Authenticator) are more secure than SMS codes (which can be intercepted via SIM swapping).
Input sanitisation / validation	SQL injection, cross-site scripting (XSS), and other injection attacks	All user input is checked, validated, and **sanitised** before being processed. Special characters that could be interpreted as code (single quotes, angle brackets, semicolons) are either escaped (treated as literal text) or stripped out. The golden rule: **never trust user input**. Use parameterised queries for database operations. Validate data type, length, range, and format before processing.
Network policies	Various threats; accidental exposure	Acceptable use policies define what users may and may not do on the network. Includes: no personal devices (or BYOD restrictions), mandatory software updates, regular password changes, not sharing passwords, reporting suspicious emails, not installing unauthorised software. Training users is crucial because many attacks exploit human error.
Software updates / patching	Known vulnerabilities exploited by	Software vendors regularly release security patches that fix discovered vulnerabilities. Unpatched systems are vulnerable to attacks that exploit these known weaknesses.

	malware and hackers	Automatic updates should be enabled where possible. The WannaCry ransomware attack in 2017 primarily affected systems that had not applied a Microsoft patch released two months earlier.

Matching Threats to Prevention Methods

```
Threat                    Primary Prevention Methods
──────────────────────    ──────────────────────────────────────────
Malware                 →  Anti-malware, software updates, user training,
                           firewall, not opening suspicious attachments
Phishing                →  User training, email filtering, 2FA (limits
                           damage even if credentials stolen), checking URLs
Brute-force             →  Strong/long passwords, account lockout, 2FA,
                           CAPTCHA, rate limiting
DDoS                    →  Firewall rules, traffic filtering, CDN services,
                           redundant servers, ISP-level mitigation
Data interception       →  Encryption (HTTPS/TLS), VPN, avoid public Wi-Fi,
                           WPA3 for wireless
SQL injection           →  Input sanitisation, parameterised queries,
                           web application firewall, penetration testing
```

Exam Tip: A firewall controls **network traffic** (allows/blocks connections based on rules); anti-malware scans **file contents** for malicious code — they are **different** and complementary. Both are needed. For prevention methods, always explain the *mechanism* (how does it actually prevent the attack?) rather than just naming it. For 2FA, name the two categories used (e.g., something you know + something you have) and explain why it helps even if the password is stolen. Always state that penetration testing requires **written authorisation** — without it, the same actions would be illegal under the Computer Misuse Act.

© RAG Learning · Not for redistribution